

Estado de revisión: Borrador de traducción asistida por máquina. Requiere revisión humana de terminología, significado, enlaces, formato y vigencia técnica antes de marcarse como edición final.

CYBERSECURITY, PRIVACY & COMPLIANCE SERIES

NIST CYBERSECURITY FRAMEWORK 2.0

Practical GRC, Implementation, Evidence, and Open-Source Tools

Un manual de trabajo para directivos, analistas junior, estudiantes, cambiadores de carrera y equipos de ciberseguridad

Alberto (Al) Leiva

Primera edición • Julio 2026

Inside: All 106 CSF Resultados básicos • Perfiles • Tiros • GRC • cadena de suministro • evidencia • pruebas de control • herramientas de código abierto • laboratorios • preparación de carrera Silencio.

Publication and Use Notice

Autor: Alberto (Al) Leiva

Edición: Primera edición, Julio 2026

Propósito: Educación gratuita y práctica para directivos, analistas junior, estudiantes, cambiadores de carrera, profesionales del riesgo y profesionales de la ciberseguridad.

Educational notice

Este manual proporciona información educativa general. No crea certificación, cumplimiento legal, opinión de auditoría o garantía de seguridad. Las organizaciones deben adaptar el NIST CSF a su misión, riesgos, obligaciones, apetito de riesgo, recursos, tecnologías y partes interesadas. Utilice fuentes oficiales actuales y asesoramiento jurídico, de riesgo, privacidad, seguridad, auditoría y técnico para decisiones reales.

Uso ético y autorizado

Utilice herramientas técnicas únicamente en sistemas, aplicaciones, redes, cuentas de nube y datos que posee o está específicamente autorizado por escrito para evaluar. Use datos ficticios, sintéticos o aprobados en el entrenamiento. La capacidad técnica no crea permiso.

Prefacio

Una introducción acogedora a la gestión práctica del riesgo de ciberseguridad.

El trabajo de ciberseguridad puede parecer una colección de productos, alertas, políticas y tareas técnicas. El Marco de Ciberseguridad NIST proporciona a esas actividades un lenguaje compartido. Ayuda a los líderes a explicar lo que importan los resultados, ayuda a los administradores a establecer prioridades y ayuda a los profesionales a conectar el trabajo diario con el riesgo organizativo.

CSF 2.0 es deliberadamente flexible. No le dice a cada organización que compre la misma herramienta, implemente el mismo control, o llegue al mismo Tier. Describe los resultados. Un hospital, fabricante, escuela, banco, startup, agencia gubernamental y sin ánimo de lucro puede utilizar el mismo núcleo al tiempo que elige diferentes prioridades e implementaciones.

Este manual sigue un enfoque basado en la metodología. Una hoja de cálculo marco es útil sólo cuando el alcance es preciso. Un panel verde es útil sólo cuando la evidencia es confiable. Un resultado del escáner es útil sólo cuando alguien valida, prioriza, corrige y lo reprueba. Los administradores siguen siendo responsables de las decisiones; los analistas toman esas decisiones mejor reuniendo hechos completos y comunicando claramente.

Cómo utilizar este manual

Los administradores deben comenzar con los Capítulos 1–3, 10–17, y las plantillas del Capítulo 22.

Los analistas juniores deben estudiar los seis capítulos de Función, método de verificación, herramientas, laboratorio y preparación de entrevistas.

Los equipos técnicos deben mapear las conclusiones a activos, riesgos, resultados CSF, implementación, propietarios, evidencia y acción correctiva.

Legal, privacy, safety, operational technology, and business teams should review decisions that affect their responsibilities.

Contenido de la palabra:** La guía del capítulo que figura a continuación contiene números de página específicos de edición después de la presentación final. El documento también contiene un campo nativo de Word TOC. Después de editar, haz clic con el botón derecho y selecciona Update Field, luego actualiza la tabla completa. Silencio.

Tabla de contenidos

[Notificación de publicación y uso \[2\]\(#publication-and-use-notice\)](#)

[Notificación educativa \[2\]\(#educational-notice\)](#)

[Uso electrónico y autorizado \[2\] \(#ethical-and-authorized-use\)](#)

[Prefacio \[3\] \(#preface\)](#)

[Cómo utilizar este manual \[4\]\(#how-to-use-this-manual\)](#)

[Tabla de contenidos \[4\]\(#table-of-contents\)](#)

[1. NIST CSF 2.0 Foundations \[9\]\(#nist-csf-2.0-foundations\)](#)

1.1 Lo que CSF 2.0 es [9](#what-csf-2.0-is)

1.2 Lo que cambió de CSF 1.1 [9](#what-changed-from-csf-1.1)

1.3 Lo que CSF 2.0 no es [9](#what-csf-2.0-is-not)

2. Recursos básicos, perfiles, niveles y recursos de apoyo [11](#core-profiles-tiers-and-supporting-resources)

3. Practical Implementation Roadmap [12](#practical-implementation-roadmap)

4. Función GOVERN [13](#govern-function)

Contexto organizador (GV.OC) [13](#organizational-context-gv.oc)

Estrategia de Gestión de Riesgos (GV.RM) [13](#risk-management-strategy-gv.rm)

Roles, responsabilidades y autoridades (GV.RR) [14](#roles-responsibilities-and-authorities-gv.rr)

Policía (GV.PO) [14](#policy-gv.po)

Oversight (GV.OV) [14](#oversight-gv.ov)

Cybersecurity Supply Chain Risk Management (GV.SC) [15](#cybersecurity-supply-chain-risk-management-gv.sc)

5. Función IDENTIFY [16](#identify-function)

Asset Management (ID.AM) [16](#asset-management-id.am)

Evaluación de Riesgos (ID.RA) [16](#risk-assessment-id.ra)

Mejoramiento (ID.IM) [17](#improvement-id.im)

6. Función del PROTECTO [18](#protect-function)

Gestión de identidad, autenticación y control de acceso (PR.AA) [18](#identity-management-authentication-and-access-control-pr.aa)

Conciencia y capacitación (PR.AT) [18](#awareness-and-training-pr.at)

Seguridad de datos (PR.DS) [18](#data-security-pr.ds)

Platform Security (PR.PS) [19](#platform-security-pr.ps)

Resiliencia de la infraestructura de tecnología (PR.IR) [19](#technology-infrastructure-resilience-pr.ir)

7. Función DETECT [21](#detect-function)

Vigilancia continua (DE.CM) [21](#continuous-monitoring-de.cm)

Análisis de eventos adversos (DE.AE) [21](#adverse-event-analysis-de.ae)

8. Función de RESPOND [23](#respond-function)

Administración de incidentes (RS.MA) [23](#incident-management-rs.ma)

Análisis de incidentes (RS.AN) [23](#incident-analysis-rs.an)

Incident Response Reporting and Communication (RS.CO) [24](#incident-response-reporting-and-communication-rs.co)

Mitigación de incidentes (RS.MI) [24](#incident-mitigation-rs.mi)

9. Función RECOVER [25](#recover-function)

Incident Recovery Plan Execution (RC.RP) [25](#incident-recovery-plan-execution-rc.rp)

Incident Recovery Communication (RC.CO) [25](#incident-recovery-communication-rc.co)

10. Perfiles de organización [26](#organizational-profiles)

10.1 Declaración del alcance del perfil [26](#profile-scope-statement)

10.2 Estado de resultados [26](#outcome-status)

10.3 Priorización de la computación [27](#gap-prioritization)

11. CSF Tiers [28](#csf-tiers)

12. Riesgo empresarial, competencia de riesgo y comunicación [29](#enterprise-risk-risk-appetite-and-communication)

12.1 Declaración de riesgo ejecutivo [29](#executive-risk-statement)

12.2 Cuestiones a nivel de la Junta [29](#board-level-questions)

13. Riesgo de cadena de suministro de ciberseguridad [30](#cybersecurity-supply-chain-risk)

14. Metrics, Evidence, and Reporting [31](#metrics-evidence-and-reporting)

14.1 Calidad de la prueba [31](#evidence-quality)

15. Verificación de Cumplimiento y Pruebas de Control [32](#compliance-verification-and-control-testing)

15.1 Pruebas prácticas de verificación [32](#practical-verification-tests)

15.2 Conclusión [33](#conclusion-language)

16. Herramientas de código abierto para CSF Work [34](#open-source-tools-for-csf-work)

16.1 Lista de verificación de validación de herramientas [34](#tool-validation-checklist)

16.2 CISO Assistant [35](#ciso-assistant)

Inicio rápido [35](#quick-start)

Evidencia y limitación [35](#evidence-and-limitation)

16.3 Wazuh [35](#wazuh)

Inicio rápido [35](#quick-start-1)

Evidencia y limitación [35](#evidence-and-limitation-1)

16.4 osquery [35](#osquery)

Inicio rápido [35](#quick-start-2)

Evidencia y limitación [36](#evidence-and-limitation-2)

16.5 OpenSCAP [36](#openscap)

Inicio rápido [36](#quick-start-3)

Evidencia y limitación [36](#evidence-and-limitation-3)

16.6 Greenbone Community Edition [36](#greenbone-community-edition)

Inicio rápido [36](#quick-start-4)

Evidencia y limitación [36](#evidence-and-limitation-4)

16.7 Trivy [36](#trivy)

Inicio rápido [36](#quick-start-5)

Evidencia y limitación [37](#evidence-and-limitation-5)

16.8 OWASP ZAP [37](#owasp-zap)

Inicio rápido [37](#quick-start-6)

Evidencia y limitación [37](#evidence-and-limitation-6)

16.9 Keycloak [37](#keycloak)

Inicio rápido [37](#quick-start-7)

Evidencia y limitación [37](#evidence-and-limitation-7)

16.10 DefectDojo [37](#defectdojo)

Inicio rápido [37](#quick-start-8)

Evidencia y limitación [37](#evidence-and-limitation-8)

16.11 Velociraptor [38](#velociraptor)

Inicio rápido [38](#quick-start-9)

Evidencia y limitación [38](#evidence-and-limitation-9)

16.12 Agente de política abierta [38](#open-policy-agent)

Inicio rápido [38](#quick-start-10)

Evidencia y limitación [38](#evidence-and-limitation-10)

16.13 OpenSearch [38](#opensearch)

Inicio rápido [38](#quick-start-11)

Evidencia y limitación [38](#evidence-and-limitation-11)

16.14 Herramientas oficiales NIST [38](#official-nist-tools)

17. Manual de juegos CSF [40](#managers-csf-playbook)

17.1 Preguntas mensuales [40](#monthly-questions)

17.2 Dashboard [40](#dashboard)

17.3 Errores comunes [40](#common-mistakes)

18. From Beginner to Junior Analyst [41](#from-beginner-to-junior-analyst)

18.1 Funciones a nivel de entrada [41](#entry-level-roles)

18.2 Trabajar un analista junior puede realizar [41](#work-a-junior-analyst-may-perform)

18.3 Prueba de cartera [42](#portfolio-proof)

19. Laboratorio de Ficción y Cartera [43](#fictional-laboratory-and-portfolio)

Proyecto 1 — Ámbito y contexto [43](#project-1-scope-and-context)

Proyecto 2 — Activo y mapa de datos [43](#project-2-asset-and-data-map)

Proyecto 3 — Riesgo [43](#project-3-risk)

Proyecto 4 — Perfiles [43](#project-4-profiles)

Proyecto 5 — Controles y pruebas [43](#project-5-controls-and-tests)

Proyecto 6 — Incident [43](#project-6-incident)

Proyecto 7 — Herramientas [43](#project-7-tools)

Proyecto 8 — Informe ejecutivo [43](#project-8-executive-report)

20. Plan de aprendizaje de 30 días [44] (#thirty-day-learning-plan)

20.1 hábito diario [44](#daily-habit)

21. Preparación de entrevistas [45](#interview-preparation)

¿Qué es NIST CSF 2.0? [45](#what-is-nist-csf-2.0)

¿Cuáles son las seis Funciones? [45](#what-are-the-six-functions)

¿Por qué fue agregado Govern? [45](#why-was-govern-added)

¿Qué es un perfil actual? [45](#what-is-a-current-profile)

¿Qué es un perfil de destino? [45](#what-is-a-target-profile)

¿Qué son los Tiers? [45](#what-are-tiers)

¿CSF certifica el cumplimiento? [45](#does-csf-certify-compliance)

¿Cómo verifica un resultado? [45](#how-do-you-verify-an-outcome)

¿Cómo deben utilizarse las herramientas? [45](#how-should-tools-be-used)

¿Cómo priorizas las brechas? [46](#how-do-you-prioritize-gaps)

22. Plantillas y listas de verificación [47](#templates-and-checklists)

22.1 Perfil [47](#profile-record)

22.2 Registro de riesgos [47](#risk-register)

22.3 Ficha de prueba de control [47](#control-test-sheet)

22.4 Examen de los proveedores [47](#supplier-review)

22.5 Lista de comprobación de la preparación del administrador [48](#manager-readiness-checklist)

23. Índice de Glosario y Asunto [49](#glossary-and-subject-index)

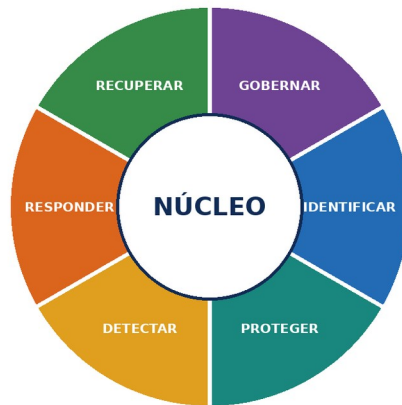
23.1 Índice de asunto [49](#subject-index)

24. Referencias oficiales y estudio ulterior [50](#official-references-and-further-study)

1. NIST CSF 2.0 Foundations

Qué marco es, qué cambió, y lo que no reclama.

Las seis Funciones del NIST CSF 2.0



Govern, Identificar, Proteger, Detectar, Responder y Recuperar el trabajo como un sistema conectado.

Figura 1. Las seis funciones NIST CSF 2.0

1.1 What CSF 2.0 is

NIST publicó CSF 2.0 el 26 de febrero de 2024. Está diseñado para organizaciones de todo tamaño, sector y nivel de sofisticación técnica. Sus resultados son nacionales, sectoriales y tecnológicamente neutros. Las organizaciones pueden adoptarlo voluntariamente o porque una política, contrato, regulador, cliente o estándar interno lo solicite.

1.2 Qué cambió desde CSF 1.1

- GOVERN se convirtió en una sexta función, colocando liderazgo, política, riesgo empresarial y responsabilidad en el centro.
- La ciberseguridad de la cadena de suministro recibió mayor énfasis.
- El lenguaje se amplió más allá de la infraestructura crítica, por lo que el marco sirve claramente a todas las organizaciones.
- Perfiles, Tiers, Ejemplos de Implementación, Referencias Informáticas y Guías de Inicio Rápido forman una cartera CSF más grande.
- Algunos números de Subcategoría contienen lagunas intencionales porque el contenido CSF 1.1 se movió dentro de CSF 2.0.

1.3 What CSF 2.0 is not

- No es una ley por sí misma.
- No es un único catálogo de control o una lista de tecnología obligatoria.

- No proporciona una puntuación universal.
- NIST no certifica organizaciones, productos, consultores o asesores contra el CSF.
- Un Tier alto no es automáticamente el objetivo adecuado para cada alcance.
- Una asignación a un resultado CSF no prueba que el resultado se alcance.

2. Core, Profiles, Tiers, and Supporting Resources

Las piezas de CSF 2.0 y cómo encajan juntos.

Jerarquía del Núcleo del CSF



Las fusiones contienen Categorías, que contienen Subcategorías específicas centradas en el resultado.

Figura 2. CSF Categoría básica

Silencio **Componente** Silencio** Silencio

----- TENIDO

ANTERIOR Una jerarquía de seis Funciones, 22 Categorías y 106 Subcategorías ANTERI
 Describir los resultados deseados de ciberseguridad tención Perfil organizacional Silencio
 Resultados actuales y/o Objetivo para un ámbito definido tención Compare postura, priori
 deficiencias, plan work TEN TEN Community Profile TENIDO Una base de referencia de
 resultados compartida para un sector, tecnología, amenaza o caso de uso TENIDO Utilizar como
 entrada a un perfil de destino organizativo TEN Silencio Tiers – Contexto para el rigor de la
 gobernanza y las prácticas de gestión de riesgos tención Aplicación Ejemplos tención Medidas
 nacionales que pueden ayudar a lograr resultados – Generar ideas; adaptar y validar Silencio
 TENCIÓN Referencias informativas TENIDA Mappings to standards, guidance, regulations, and

other sources TENS Select more detailed practices and controls TEN Guías de inicio rápido – Guía de acción corta sobre los usos CSF específicos

Silencio **Números que importan:** CSF 2.0 contiene 6 Funciones, 22 Categorías y 106 Subcategorías. Las Subcategorías describen los resultados, los productos no requeridos o las implementaciones idénticas. Silencio Silencio.

3. hoja de ruta de aplicación práctica

Una forma repetible de pasar del lenguaje marco a mejoras financiadas.

- Nombra un patrocinador ejecutivo y dueño del programa.
- Definir el alcance del perfil: empresa, unidad de negocio, producto, servicio, sistema, región o ecosistema de proveedores.
- Reunir la misión, los interesados directos, legales, contractuales, riesgos, activos, amenazas, incidentes, auditoría, fuerza de trabajo e información de proveedores.
- Seleccione los resultados CSF aplicables y cree un perfil actual utilizando pruebas fiables.
- Definir un perfil objetivo basado en el riesgo, considerando los perfiles y obligaciones de la comunidad.
- Analizar las deficiencias, dependencias, costos, viabilidad y reducción del riesgo.
- Crear un plan de acción aprobado con propietarios, recursos, hitos, medidas y protección provisional.
- Implementar controles y procedimientos operativos.
- Diseño de pruebas y eficacia operativa con poblaciones completas y muestras representativas.
- Reportar riesgos, decisiones, excepciones, progreso y limitaciones.
- Actualizar Perfiles después de cambios materiales, incidentes, ejercicios, revisiones o cambios de riesgo.

Silencio **Empieza pequeña sin perder integridad:** Una pequeña organización puede comenzar con un servicio crítico o un proceso de alto riesgo. Mantener el alcance honesto, registrar exclusiones, y expandirse deliberadamente. Silencio Silencio.

4. Función de gobierno

Un completo desglose de idiomas de cada categoría y subcategoría GOVERN.

Silencio **Propósito de la reflexión** Establecer dirección, expectativas, rendición de cuentas, política, supervisión y gestión del riesgo de cadena de suministro. Silencio Silencio...

Organizational Context (GV.OC)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
 Silencio **Excelente evidencia** Silencio

----- La vida

----- Silencio GV.OC-01 TENIDO Conectar las decisiones de ciberseguridad a la misión de la organización. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención de misiones y registros de los interesados, registro de obligaciones, mapa de dependencia Silencio GV.OC-02 ANTE Identifique a los interesados y considere sus expectativas de seguridad cibernética. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención de misiones y registros de los interesados, registro de obligaciones, mapa de dependencia tención GV.OC-03 ANTE Identifique y gestione las obligaciones legales, regulatorias, contractuales, de privacidad y de liberación civil. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención de misiones y registros de los interesados, registro de obligaciones, mapa de dependencia Silencio GV.OC-04 ANTE Entender y comunicar los servicios críticos que otros esperan de la organización. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención de misiones y registros de los interesados, registro de obligaciones, mapa de dependencia Silencio GV.OC-05 ANTE Entender y comunicar los resultados externos, capacidades y servicios que la organización depende. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención de misiones y registros de los interesados, registro de obligaciones, mapa de dependencia

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

Risk Management Strategy (GV.RM)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
 Silencio **Excelente evidencia** Silencio

----- tención GV.RM-01 Silencio Acorde on cybersecurity risk-
management objectives with relevant stakeholders. tención Confirme la propiedad, alcance,

implementación, revisión, excepciones, acción correctiva y operación repetible. permanente riesgo apetito, método, registro de riesgo de empresa, vías de presentación de informes Silencio GV.RM-02 ANTE Establece, comunica y mantiene declaraciones de riesgo de apetito y tolerancia. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. permanente riesgo apetito, método, registro de riesgo de empresa, vías de presentación de informes tención GV.RM-03 ANTE Integrar el riesgo de ciberseguridad en los procesos de gestión de riesgos institucionales. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. permanente riesgo apetito, método, registro de riesgo de empresa, vías de presentación de informes Silencio GV.RM-04 ANTE Define y comunica opciones aceptables de respuesta al riesgo. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. permanente riesgo apetito, método, registro de riesgo de empresa, vías de presentación de informes Silencio GV.RM-05 ANTE Crear rutas de comunicación para los riesgos cibernéticos, incluyendo los riesgos de proveedor y terceros. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. permanente riesgo apetito, método, registro de riesgo de empresa, vías de presentación de informes tención GV.RM-06 ANTE Utiliza un método consistente para calcular, documentar, categorizar y priorizar los riesgos cibernéticos. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. permanente riesgo apetito, método, registro de riesgo de empresa, vías de presentación de informes Silencio GV.RM-07 Silencio Incluye oportunidades beneficiosas y riesgo positivo en discusiones de ciberseguridad. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. permanente riesgo apetito, método, registro de riesgo de empresa, vías de presentación de informes

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

Roles, Responsibilities, and Authorities (GV.RR)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
 Silencio **Excelente evidencia** Silencio

————— Silencio GV.RR-01 Silencio Liderazgo acepta la rendición de cuentas por el riesgo de ciberseguridad y apoya una cultura ética y mejorada. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención RACI, descripciones de funciones, presupuesto, registros de la fuerza de trabajo Silencio GV.RR-02 ANTE Establezca, comuniqué, entienda y haga cumplir funciones, responsabilidades y autoridad cibernéticas. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención RACI, descripciones de funciones, presupuesto, registros de la fuerza de trabajo Silencio GV.RR-03 TENIDO Asignar personas, dinero, tecnología y tiempo en línea con la estrategia y la política de riesgo. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

Silencio GV PQ-01 ANTE Establecer

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

----- tensión GV OV-01

	tención GV.OV-01
Silencio Revisión de los resultados de la estrategia y utilizarlos para ajustar la dirección.	tención
Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. Silencio, minutos de reunión, decisiones, cambios de estrategia	Silencio
GV.OV-02 ANTE Ajustar la estrategia de riesgo cuando los requisitos o riesgos no están completamente cubiertos.	tención Confirme la propiedad, alcance, implementación, revisión,
excepciones, acción correctiva y operación repetible. Silencio, minutos de reunión, decisiones, cambios de estrategia	Silencio
GV.OV-03 Silencio Evaluar el rendimiento de la ciberseguridad y determinar los cambios necesarios.	tención Confirme la propiedad, alcance, implementación,

revisión, excepciones, acción correctiva y operación repetible. Silencio, minutos de reunión, decisiones, cambios de estrategia

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

Cybersecurity Supply Chain Risk Management (GV.SC)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
Silencio **Excelente evidencia** Silencio

—— Silencio GV.SC-01 ANTE Establecer un programa de riesgo acordado de cadena de suministro, estrategia, objetivos, políticas y procesos. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención de proveedores, envío, diligencia debida, contratos, monitoreo, prueba de salida Silencio GV.SC-02 Silencio Coordinar funciones de ciberseguridad para proveedores, clientes, socios y propietarios internos. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención de proveedores, envío, diligencia debida, contratos, monitoreo, prueba de salida tención GV.SC-03 ANTE Integrar el riesgo de cadena de suministro en el trabajo de ciberseguridad, ERM, evaluación y mejora. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención de proveedores, envío, diligencia debida, contratos, monitoreo, prueba de salida Silencio GV.SC-04 ANTE Conoce a los proveedores y priorízalos por la crítica. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención de proveedores, envío, diligencia debida, contratos, monitoreo, prueba de salida Silencio GV.SC-05 ANTE Put prior cybersecurity requirements into contracts and agreements. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención de proveedores, envío, diligencia debida, contratos, monitoreo, prueba de salida Silencio GV.SC-06 ANTE Perform planeamiento y diligencia debida antes de comenzar relaciones de terceros. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención de proveedores, envío, diligencia debida, contratos, monitoreo, prueba de salida Silencio GV.SC-07 Silencio Record, evaluar, responder y supervisar los riesgos de proveedor, producto, servicio y terceros. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención de proveedores, envío, diligencia debida, contratos, monitoreo, prueba de salida Silencio GV.SC-08 ANTE Include relevant third parties in incident planning, response, and recovery. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención de proveedores, envío, diligencia debida, contratos, monitoreo, prueba de salida Silencio GV.SC-09 Silencio Monitor seguridad de cadena de suministro en todo el ciclo de vida del producto y servicio tecnológico. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención de proveedores, envío, diligencia debida, contratos, monitoreo, prueba de salida Silencio GV.SC-10 Silencio Planifique actividades de seguridad para el fin de un

acuerdo de asociación o servicio. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención de proveedores, envío, diligencia debida, contratos, monitoreo, prueba de salida

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

5. Función IDENTIFY

Un desglose completo de todas las categorías y subcategorías IDENTIFY.

Silencio **Propósito de la reflexión** Comprender activos, dependencias, amenazas, vulnerabilidades, riesgos y necesidades de mejora. Silencio Silencio.

Asset Management (ID.AM)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
Silencio **Excelente evidencia** Silencio

----- Silencio ID.AM-01 ANTE Mantener un inventario de hardware gestionado. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. inventarios de activos y datos, propietarios, diagramas, registros de ciclo de vida Silencio ID.AM-02 ANTE Mantener un inventario de software, servicios y sistemas gestionados. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. inventarios de activos y datos, propietarios, diagramas, registros de ciclo de vida Silencio ID.AM-03 ANTE Mantener los diagramas actuales de comunicación de red autorizada y flujos de datos. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. inventarios de activos y datos, propietarios, diagramas, registros de ciclo de vida Silencio ID.AM-04 ANTE Mantener un inventario de servicios proporcionados por proveedores. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. inventarios de activos y datos, propietarios, diagramas, registros de ciclo de vida Silencio ID.AM-05 ANTE Priorizar activos mediante clasificación, crítica, recursos e impacto de la misión. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. inventarios de activos y datos, propietarios, diagramas, registros de ciclo de vida tención ID.AM-07 ANTE Inventory designe tipos de datos y sus metadatos. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. inventarios de activos y datos, propietarios, diagramas, registros de ciclo de vida Silencio ID.AM-08 Silencio Manage systems, hardware, software, servicios y datos a lo largo de sus ciclos de vida. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción

correctiva y operación repetible. inventarios de activos y datos, propietarios, diagramas, registros de ciclo de vida

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

Risk Assessment (ID.RA)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
Silencio **Excelente evidencia** La inmortalidad

----- La inmortalidad Silencio ID.RA-01 ANTE Identificar, validar y registrar vulnerabilidades de activos. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. Registros de amenazas y vulnerabilidad, análisis de riesgos, tratamiento y excepciones Silencio ID.RA-02 Silencio Recibir inteligencia de amenazas cibernéticas de fuentes adecuadas de intercambio. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. Registros de amenazas y vulnerabilidad, análisis de riesgos, tratamiento y excepciones Silencio ID.RA-03 ANTE Identificar y registrar amenazas internas y externas. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. Registros de amenazas y vulnerabilidad, análisis de riesgos, tratamiento y excepciones Silencio ID.RA-04 ANTE Estimar la probabilidad y el impacto de las amenazas explotando vulnerabilidades. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. Registros de amenazas y vulnerabilidad, análisis de riesgos, tratamiento y excepciones Silencio ID.RA-05 ANTE Utilizar amenazas, vulnerabilidades, probabilidad e impacto para entender el riesgo y prioridades inherentes. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. Registros de amenazas y vulnerabilidad, análisis de riesgos, tratamiento y excepciones Silencio ID.RA-06 Silencio Elige, prioriza, plan, rastrea y comunica respuestas de riesgo. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. Registros de amenazas y vulnerabilidad, análisis de riesgos, tratamiento y excepciones Silencio ID.RA-07 Silencio Evaluar, registrar, aprobar y seguir el efecto de riesgo de cambios y excepciones. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. Registros de amenazas y vulnerabilidad, análisis de riesgos, tratamiento y excepciones tención ID.RA-08 ANTE Establecer un proceso para recibir, analizar y responder a las revelaciones de vulnerabilidad. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. Registros de amenazas y vulnerabilidad, análisis de riesgos, tratamiento y excepciones Silencio ID.RA-09 ANTE Assess hardware y software autenticidad e integridad antes de la adquisición y uso. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. Registros de amenazas y vulnerabilidad, análisis de riesgos, tratamiento y excepciones Silencio ID.RA-10 ANTE Evaluar proveedores críticos antes de la adquisición. tención Confirme la propiedad, alcance, implementación, revisión, excepciones,

acción correctiva y operación repetible. Registros de amenazas y vulnerabilidad, análisis de riesgos, tratamiento y excepciones

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

Improvement (ID.IM)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
Silencio **Excelente evidencia** Silencio

Identifique las mejoras de las evaluaciones. tención ID.IM-01 ANTE Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. evaluación, ejercicio, lecciones, acciones correctivas, planes actualizados Silencio ID.IM-02 ANTE Identifique las mejoras de las pruebas y ejercicios, incluyendo ejercicios coordinados de terceros. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. evaluación, ejercicio, lecciones, acciones correctivas, planes actualizados Silencio ID.IM-03 ANTE Identifique las mejoras durante los procesos operativos, procedimientos y actividades. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. evaluación, ejercicio, lecciones, acciones correctivas, planes actualizados Silencio ID.IM-04 ANTE Establezca, comunique, mantenga y mejore los planes de ciberseguridad operacional y de respuesta a incidentes. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. evaluación, ejercicio, lecciones, acciones correctivas, planes actualizados

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

6. Función del PROTECTO

Un desglose completo de todas las categorías y subcategorías PROTECT.

Silencio **Propósito de la reflexión** Use salvaguardias que reduzcan la probabilidad y el impacto de los eventos de ciberseguridad. Silencio...

Identity Management, Authentication, and Access Control (PR.AA)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
Silencio **Excelente evidencia** Silencio

— Silencio PR.AT-01 Silencio Dar al personal los conocimientos y habilidades para realizar el trabajo ordinario con el riesgo cibernético en mente. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención de planes de estudios basados en roles, lista, finalización, ejercicios, seguimiento Silencio PR.AT-02 Silencio Dar a la gente en funciones especializadas los conocimientos y habilidades de ciberseguridad que estos roles requieren. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención de planes de estudios basados en roles, lista, finalización, ejercicios, seguimiento

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

Data Security (PR.DS)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
Silencio **Excelente evidencia** Silencio

— Silencio PR.DS-01 Silencio Protege los datos en reposo para la confidencialidad, integridad y disponibilidad. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. clasificación, configuración de cifrado, registros DLP, pruebas de copia de seguridad y restauración Silencio PR.DS-02 Silencio Protege los datos en tránsito para la confidencialidad, integridad y disponibilidad. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. clasificación, configuración de cifrado, registros DLP, pruebas de copia de seguridad y restauración Silencio PR.DS-10 Silencio Protege los datos en uso para la confidencialidad, integridad y disponibilidad. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. clasificación, configuración de cifrado, registros DLP, pruebas de copia de seguridad y restauración Silencio PR.DS-11 ANTE Crear, proteger, mantener y probar copias de seguridad. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. clasificación, configuración de cifrado, registros DLP, pruebas de copia de seguridad y restauración

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

Platform Security (PR.PS)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
Silencio **Excelente evidencia** Silencio

----- tención PR.PS-01 ANTE Establezca y aplique prácticas de gestión de configuración. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. Bases de referencia, parches y registros de EOL, registros, percepciones, pruebas de SDLC seguras TENIDO PR.PS-02 ANTE Mantener, reemplazar y eliminar el software según el riesgo. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. Bases de referencia, parches y registros de EOL, registros, percepciones, pruebas de SDLC seguras Silencio PR.PS-03 Silencio Mantener, reemplazar y eliminar hardware de acuerdo con el riesgo. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención Baselines, parches y registros de EOL, registros, persecuciones, pruebas de SDLC seguras Silencio PR.PS-04 ANTE Genera registros y hazlos disponibles para el monitoreo continuo. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tención Baselines, parches y registros de EOL, registros, persecuciones, pruebas de SDLC seguras Silencio PR.PS-05 Silencio Prevent installation and execution of unauthorized software. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. Bases de referencia, parches y registros de EOL, registros, percepciones, pruebas de SDLC seguras Silencio PR.PS-06 ANTE Integrar y supervisar prácticas seguras de desarrollo de software durante todo el ciclo de vida. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. Bases de referencia, parches y registros de EOL, registros, percepciones, pruebas de SDLC seguras

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

Technology Infrastructure Resilience (PR.IR)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
Silencio **Excelente evidencia** Silencio

Silencio PR.IR-01 Silencio Protege las redes y entornos de acceso y uso lógico no autorizados. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. arquitectura, segmentación, controles ambientales, resistencia y pruebas de capacidad Silencio PR.IR-02 Silencio Protege los activos tecnológicos de las amenazas ambientales. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. arquitectura, segmentación, controles ambientales, resistencia y pruebas de capacidad tención PR.IR-03 Silencio Aplicar mecanismos que satisfagan las necesidades de resiliencia durante las condiciones normales y adversas. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. arquitectura, segmentación, controles ambientales, resistencia y pruebas de capacidad Silencio PR.IR-04 TEN Mantener suficiente capacidad de recursos para apoyar la disponibilidad. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. arquitectura, segmentación, controles ambientales, resistencia y pruebas de capacidad

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

7. Función de DETECT

Un desglose completo de todas las categorías y subcategorías DETECT.

Silencio **Propósito de la reflexión** Monitorear y analizar eventos para encontrar ataques potenciales y compromisos. Silencio Silencio...

Continuous Monitoring (DE.CM)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
Silencio **Excelente evidencia** La inmortalidad

----- La vida eterna- tención DE.CM-01 Silencio Monitor de redes y servicios de red para eventos potencialmente adversos. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. inventario de cobertura, telemetría, alertas, registros de revisión, monitoreo de proveedores tención DE.CM-02 TENIDO Supervisar el entorno físico para eventos potencialmente adversos. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. inventario de cobertura, telemetría, alertas, registros de revisión, monitoreo de proveedores tención DE.CM-03 Silencio Monitor actividad de personal y uso tecnológico para eventos potencialmente adversos. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. inventario de cobertura, telemetría, alertas, registros de revisión, monitoreo de proveedores Silencio DE.CM-06 Silencio Monitor external service-provider activities and services for adverse events. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. inventario de cobertura, telemetría, alertas, registros de revisión, monitoreo de proveedores Silencio DE.CM-09 Silencio Monitor hardware, software, entornos de tiempo de ejecución y datos para eventos

adversos. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. inventario de cobertura, telemetría, alertas, registros de revisión, monitoreo de proveedores

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

Adverse Event Analysis (DE.AE)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
Silencio **Excelente evidencia** Silencio

La vida eterna– Silencio DE.AE-02 ANTE Analyze eventos potencialmente adversos para entender la actividad relacionada. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. reglas de correlación, alertas enriquecidas, análisis de impactos, registro de declaraciones tención DE.AE-03 Silencio Correlate information from multiple sources. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. reglas de correlación, alertas enriquecidas, análisis de impactos, registro de declaraciones tención DE.AE-04 ANTE Estimar el alcance y el impacto de los eventos adversos. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. reglas de correlación, alertas enriquecidas, análisis de impactos, registro de declaraciones Silencio DE.AE-06 Silencio Proporcionar información de eventos adversos a personas y herramientas autorizadas. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. reglas de correlación, alertas enriquecidas, análisis de impactos, registro de declaraciones Silencio DE.AE-07 ANTE Utiliza inteligencia de amenazas y contexto en el análisis de eventos. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. reglas de correlación, alertas enriquecidas, análisis de impactos, registro de declaraciones Silencio DE.AE-08 Silencio Declarar incidentes cuando los eventos cumplen criterios definidos. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. reglas de correlación, alertas enriquecidas, análisis de impactos, registro de declaraciones

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

8. Función de RESPOND

Un completo desglose de idiomas de cada categoría y subcategoría RESPOND.

Silencio **Propósito de la reflexión** Administrar, analizar, comunicar, contener y erradicar incidentes declarados. Silencio Silencio.

Incident Management (RS.MA)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
Silencio **Excelente evidencia** Silencio

----- Silencio RS.MA-01
Silencio Ejecute el plan de respuesta con terceros relevantes después de que se declare un incidente. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. plan de incidentes, entradas, triaje, prioridad, escalada, decisión de recuperación Silencio RS.MA-02 TENIDO Triage y validar informes de incidentes. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. plan de incidentes, entradas, triaje, prioridad, escalada, decisión de recuperación Silencio RS.MA-03 ANTE Categorizar y priorizar incidentes. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. plan de incidentes, entradas, triaje, prioridad, escalada, decisión de recuperación Silencio RS.MA-04 Silencio Escalar o elevar incidentes cuando sea necesario. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. plan de incidentes, entradas, triaje, prioridad, escalada, decisión de recuperación Silencio RS.MA-05 ANTE Aplicar criterios para iniciar la recuperación. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. plan de incidentes, entradas, triaje, prioridad, escalada, decisión de recuperación

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

Incident Analysis (RS.AN)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
Silencio **Excelente evidencia** Silencio

----- La vida-
tención RS.AN-03 TENIDO Determinar qué ocurrió e identificar la causa raíz. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tiempo, notas forenses, registros de pruebas, hashes, análisis de causas profundas Silencio RS.AN-06 ANTERI Record investigative actions and preserve record integrity and provenance. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tiempo, notas forenses, registros de pruebas, hashes, análisis de causas profundas Silencio RS.AN-07 Silencio Recopilar datos de incidentes y metadatos preservando la integridad y la procedencia. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. tiempo, notas forenses, registros de pruebas, hashes, análisis de causas profundas tención RS.AN-08 ANTE Estimación y valida la magnitud del incidente. tención Confirme la propiedad, alcance,

implementación, revisión, excepciones, acción correctiva y operación repetible. tiempo, notas forenses, registros de pruebas, hashes, análisis de causas profundas

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

Incident Response Reporting and Communication (RS.CO)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
Silencio **Excelente evidencia** Silencio

————— La vida eterna— Silencio RS.CO-02 ANTE Notify
required internal and external stakeholders. tención Confirme la propiedad, alcance,
implementación, revisión, excepciones, acción correctiva y operación repetible. matriz de
notificación, mensajes, aprobaciones, registros de entrega Silencio RS.CO-03 Silencio Comparte
información con los interesados designados. tención Confirme la propiedad, alcance,
implementación, revisión, excepciones, acción correctiva y operación repetible. matriz de
notificación, mensajes, aprobaciones, registros de entrega

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

Incident Mitigation (RS.MI)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
Silencio **Excelente evidencia** Silencio

————— La vida eterna— Silencio RS.MI-01 Silencio Contiene incidentes. tención Confirme la
propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación
repetible. medidas de contención y erradicación, validación, decisión de riesgo residual tención
RS.MI-02 Silencio Erradicar incidentes. tención Confirme la propiedad, alcance,
implementación, revisión, excepciones, acción correctiva y operación repetible. medidas de
contención y erradicación, validación, decisión de riesgo residual

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

9. Función RECIBIDA

Un desglose completo de todas las categorías y subcategorías RECOVER.

Silencio **Propósito de la reflexión** Restaurar activos y operaciones y comunicar el progreso de
recuperación. Silencio...

Incident Recovery Plan Execution (RC.RP)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
Silencio **Excelente evidencia** Silencio

————— Silencio RC.RP-01 Silencio Ejecuta las actividades de recuperación cuando el proceso del incidente inicia la recuperación. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. plan de recuperación, restaurar registros, cheques de integridad, validación de servicios, cierre Silencio RC.RP-02 ANTE Select, scope, prioritize, and perform recovery actions. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. plan de recuperación, restaurar registros, cheques de integridad, validación de servicios, cierre Silencio RC.RP-03 Silencio Verificar la integridad de respaldo y restauración antes de la restauración. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. plan de recuperación, restaurar registros, cheques de integridad, validación de servicios, cierre Silencio RC.RP-04 ANTE Utiliza las necesidades de la misión y el riesgo cibernético para establecer las condiciones de funcionamiento posteriores al incidente. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. plan de recuperación, restaurar registros, cheques de integridad, validación de servicios, cierre Silencio RC.RP-05 Silencio Verificar los activos restaurados, restaurar el servicio y confirmar el estado operativo normal. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. plan de recuperación, restaurar registros, cheques de integridad, validación de servicios, cierre Silencio RC.RP-06 Silencio Declare recuperación completa utilizando criterios y terminar documentación de incidentes. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. plan de recuperación, restaurar registros, cheques de integridad, validación de servicios, cierre

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

Incident Recovery Communication (RC.CO)

Silencio **Responde** Silencio **Plain meaning** Silencio **Manager or analista verification**
Silencio **Excelente evidencia** Silencio

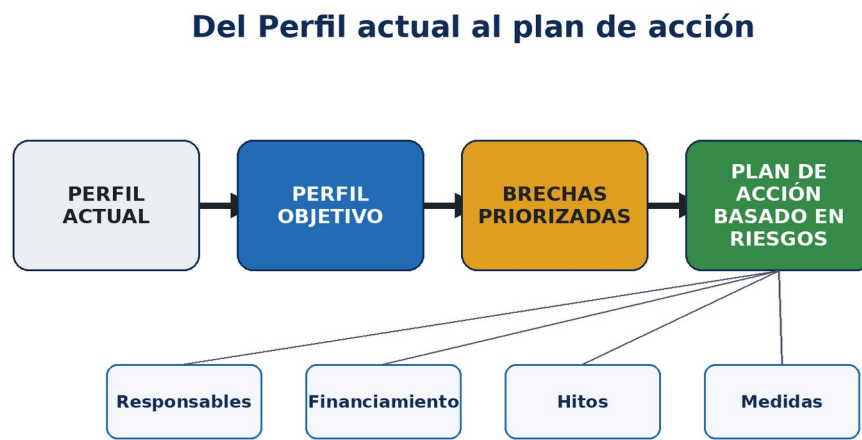
————— La vida eterna... Silencio RC.CO-03 Silencio Comuníquese el progreso de recuperación y la capacidad restaurada a los interesados designados. tención Confirme la propiedad, alcance, implementación, revisión, excepciones, acción correctiva y operación repetible. actualizaciones de las partes interesadas, mensajes públicos aprobados, prueba de entrega Silencio RC.CO-04 Silencio Edición de actualizaciones de recuperación pública a través de métodos aprobados y mensajería. tención Confirme la propiedad, alcance, implementación,

revisión, excepciones, acción correctiva y operación repetible. actualizaciones de las partes interesadas, mensajes públicos aprobados, prueba de entrega

Importante: Los resultados de CSF no son una lista de verificación de las tecnologías requeridas. Seleccione métodos y controles de aplicación de acuerdo con el riesgo, la misión, las obligaciones, los recursos y el perfil de objetivos abarcado.

10. Perfiles organizacionales

Cómo describir la postura actual, establecer un objetivo y construir un plan de acción priorizado.



A Target Profile es útil cuando sus brechas se convierten en acción de propiedad, financiada y basada en el riesgo.

Gráfico 3 Perfil actual del plan de acción

10.1 Declaración de alcance del perfil

- Con fines empresariales o de misión
- Sistemas, servicios, datos, instalaciones, personas, proveedores y lugares incluidos
- Período de tiempo y fecha de prueba
- Los interesados y la autoridad de decisión
- Entradas legales, contractuales, de política y de perfil comunitario
- Sumas, exclusiones, dependencias y limitaciones

10.2 Outcome status

Status Silencioso** Silencio

----- Silencio Conseguido El resultado abarcado se implementa y opera como el propietario previsto, la población completa, el diseño, pruebas operativas, pruebas y conclusión Silencio TENIDO Parcialmente logrado TENIDO Alguna extensión o operación está desaparecida o inconsistente ANTEExact gap, affected risk, interim action, owner and date TEN Silencio no alcanzado El resultado es aplicable pero no operando Silencioso decisión, tratamiento, recursos, cronograma Silencio No aplicable El resultado no se aplica a este ámbito definido tención Solución documentada y aprobación Silencio No evaluado Silencio La evidencia no es suficiente para una conclusión

10.3 Gap prioritization

Priorizar las lagunas que utilizan el impacto de la misión, la probabilidad de amenaza, la crítica de activos, las obligaciones jurídicas y contractuales, la exposición, las dependencias, la seguridad, la privacidad, los controles actuales, el tiempo para explotar, el esfuerzo de rehabilitación y los recursos disponibles. No clasificar las brechas sólo por la etiqueta de gravedad del escáner.

11. CSF Tiros

Uso parcial, riesgo informado, repetible y adaptable sin convertirlos en una partitura.

“Tiers proveen un contexto para la gobernanza y el rigor de la gestión del riesgo.” /

Gráfico 4 Tiros

Silencio **Tier** Silencio **Plain meaning** La vida----- La vida

----- La vida eterna... tención Tier 1 - Prácticas parciales de duración son en gran medida ad hoc, irregulares e incoherentes por objetivos o amenazas. Ejemplos de decisiones caso por caso y procesos desaparecidos en toda la organización tención Tier 2 — Riesgo informado tención Gestión aprueba prácticas de riesgo, pero no se establecen de forma sistemática en toda la organización. Silencio Prácticas aprobadas, aplicación local, riesgo parcial y sensibilización de los proveedores tención Tier 3 — Las políticas repetibles y las prácticas repetibles se definen, implementan, revisan y actualizan en toda la organización. Silencio Política aprobada, ejecución coherente, funciones calificadas, intercambio regular de información y acción de proveedores tención Tier 4 — Adaptive tención La gestión del riesgo es parte de la cultura y se adapta a través de lecciones, información predictiva y conciencia casi real. — Decisiones integradas de la GRI, controles adaptativos, mejora continua y acción oportuna de riesgo de proveedor

- Escoge Tiers para un perfil definido, no como una etiqueta de empresa vaga.
- Utilice el riesgo, la misión, las obligaciones, el costo y el beneficio para elegir el nivel de destino.

- No promedio números Tier en una puntuación engañosa.
- Documentar pruebas y diferencias entre Funciones.
- Evaluar cuando el riesgo, la misión, los proveedores o la tecnología cambia materialmente.

12. Riesgo empresarial, riesgo competitivo y comunicación

Connecting cybersecurity with executive and board decisions.

Silencio Concepto Silencio. El apetito por el riesgo permanente La cantidad amplia y el tipo de riesgo que la organización está dispuesta a perseguir o retener a las personas sometidas Muy bajo apetito por la interrupción de los servicios de emergencia tención de la tolerancia al riesgo Silencio Variación aceptable específica alrededor de los objetivos Silencio No más de cuatro horas de superación para un servicio crítico definido Silencio Riesgo hereditario tención Riesgo antes de considerar controles Silencio Servicio de cara a Internet con datos valiosos y amenazas activas TENIDO Riesgo residual TENIDO Riesgo restante después de los controles ANTE Mantener el riesgo de fuga o violación después de la MFA, segmentación, monitoreo y recuperación Silencio Respuesta al riesgo Aceptar, evitar, mitigar, transferir/compartir, o aprovechar la oportunidad – Retire software no compatible, reducir la exposición, asegurar una porción residual tención Riesgo positivo – Opportunity que puede mejorar los objetivos tención Automatización segura que reduce el error y mejora la velocidad de detección

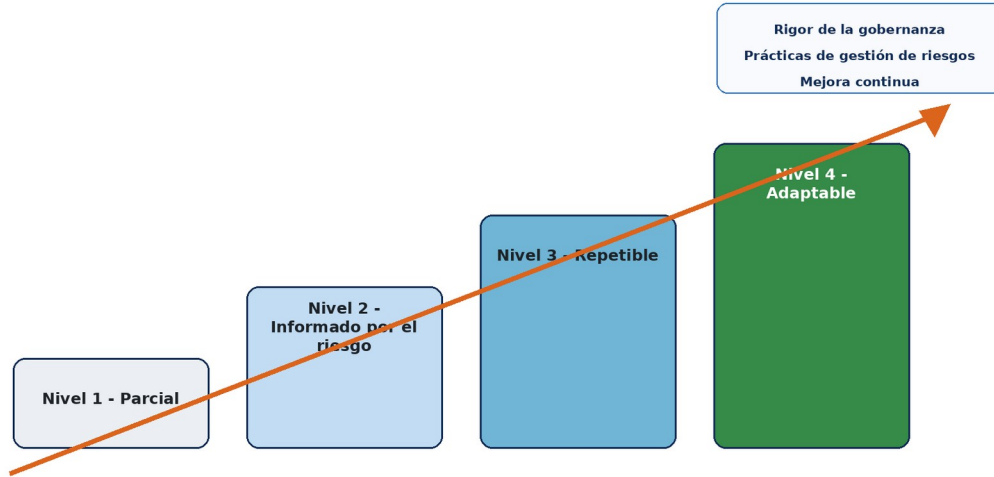
12.1 Declaración de riesgo ejecutivo

tención **Pattern:** Debido a que [threat] podría explotar [vulnerabilidad] afectando [asset o objetivo], la organización puede experimentar [Impacto del negocio]. Controles existentes [summary] dejar [exposición residual]. Administración debe [response] de [date], propiedad de [role], y monitor [measure]. Silencio Silencio.

12.2 Cuestiones a nivel de la Junta

- ¿Qué objetivos de misión y servicios críticos enfrentan el mayor riesgo cibernético?
 - ¿Qué riesgo supera el apetito o la tolerancia?
 - ¿Qué decisiones requieren financiación o aceptación de riesgos?
 - ¿Cuán confiable es la evidencia detrás del estado reportado?
 - ¿Dónde están las concentraciones de proveedores y puntos de fracaso?
 - ¿Qué nos enseñaron incidentes, ejercicios, auditorías y faltas cercanas?
 - ¿Se han probado las capacidades de recuperación para los servicios más importantes?
13. Riesgo de cadena de suministro de ciberseguridad
- Gestionar proveedores, productos, servicios y dependencias en todo el ciclo de vida*.

Niveles de Implementación del CSF



Plan, select, contract, monitor, y salida con responsabilidades de seguridad definidas

Gráfico 5 Ciclo de vida de ciberseguridad en cadena de suministro

1. Proveedores de inventario, subcontratistas, productos, servicios, flujos de datos, acceso, ubicaciones y dependencias.
2. Relaciones más estrechas por crítica, sensibilidad, acceso, sustitución, concentración, seguridad e impacto operacional.
3. Realizar diligencia debida proporcional antes de la compra o renovación.
4. Colocar funciones de ciberseguridad, incidentes, notificación, pruebas, subcontratistas, resiliencia, retorno y destrucción mensurables en los acuerdos.
5. Supervisar los cambios, las conclusiones, los incidentes, la salud financiera, el rendimiento de los servicios y las dependencias materiales de cuartas partes.
6. Incluir a terceros críticos en ejercicios, respuesta, recuperación y comunicación.
7. Al salir, eliminar el acceso, recuperar activos, devolver o destruir datos, transferir conocimientos, conservar los registros necesarios y validar la terminación.

Silencio Advertencia de contrato: Un cuestionario o cláusula contractual no prueba que los controles de un proveedor funcionan. Combinar los derechos contractuales con pruebas basadas en el riesgo, monitoreo, información de incidentes y seguimiento de la acción correctiva. Silencio.

14. Métricas, pruebas y informes

Medidas que apoyan decisiones en lugar de producir paneles decorativos.

— — — — tensión de la aplicación permanente ¿Se ha desplegado la salvaguardia? tensión
Porcentaje de cuentas privilegiadas in-scope utilizando MFA resistente al phishing Ø Medida de
funcionamiento ¿Está funcionando consistentemente? tensión Porcentaje de cuentas
terminadas discapacitadas dentro del tiempo aprobado Silencioso indicador de riesgo ¿La
exposición aumenta? tensión vulnerabilidades críticas anteriores fecha límite basado en el
riesgo en los activos de Internet Silencioso ¿Está ocurriendo el resultado deseado? Reducción de
los eventos de acceso no autorizado para el servicio ampliado ¿Puede la organización continuar
y recuperarse? tensión Porcentaje de restauraciones de servicios críticos que cumplen los
objetivos de recuperación TEN Silencio Medida de calidad de prueba Silencio ¿Se puede confiar
en el estado? tensión Porcentaje de conclusiones de resultados apoyadas por poblaciones
completas y pruebas independientes

Figure 6. Outcome-to-evidence chain

Silencio** Calidad** Silencio

----- TEN Weak

Silencio Declaración verbal, captura de pantalla sin fecha, exportación parcial, resumen sin soporte TENENCIA Solicite fuente, fecha, alcance, población, propietario, revisor, e identidad del sistema TEN UTILIZADO TENIDO Informe del sistema Fechado ligado al alcance y el período correctos ANTE Confirme configuración, integridad, acceso, interpretación y excepciones tención Strong Silencio Datos del sistema más revisión independiente, decisiones, acción correctiva, y retest |

Cómo determinar si se logra un resultado CSF con alcance.

Silencio Distinción importante: La alineación CSF no es automáticamente el cumplimiento legal, la certificación o una opinión de auditoría. Pruebe las obligaciones y controles reales que se aplican a la organización, luego utilice los resultados de CSF para organizar y comunicar resultados. Silencio Silencio.

1. Definir el desenlace CSF, riesgo, control, propietario, sistemas, ubicaciones, población, período, frecuencia y pruebas esperadas.
2. Evaluar el diseño de control: ¿el control, si se realiza como se describe, alcanzaría razonablemente el resultado previsto?
3. Obtener la población completa y probar su integridad y exactitud contra una fuente independiente.

4. Elija una muestra basada en el riesgo que cubra las fechas, sistemas, propietarios, ubicaciones, artículos inusuales y fallos pertinentes.
5. Inspeccione pruebas y, cuando sea práctico, repereforme o confirme independientemente el resultado de control.
6. Record exceptions with exact criteria, facts, duration, affected assets, cause, likelihood, impact, and existing protection.
7. Assign corrective action, interim protection, owner, resources, due date, and escalation.
8. Repueba la corrección en toda la población afectada y escribe una conclusión clara con limitaciones.

15.1 Pruebas de verificación práctica

Silencio ** Área de control** Silencioso **Populación y muestra** Silencio

----- La vida eterna- Ø Inventario de activos de activos in-scope; muestra crítica, nueva, nube, remota, administrada por proveedores, y artículos retirados TENENCIA Reconcile inventario con identidad, red, nube, adquisiciones, vulnerabilidad y fuentes de punto final ANTERI Exportaciones, reconciliación, propiedad, lagunas, corrección y retest ANTERIED Acceder a la vida útil Todos los afiliados, mudanzas, levadores, servicio y cuentas privilegiadas TEN Comparar aprobaciones y necesidades de función con los tiempos de provisión, revisión, cambio y eliminación TEN las poblaciones RRH/IAM, aprobaciones, comentarios, entradas, registros, excepciones TEN Vulnerability management TEN Todos los activos y hallazgos; muestra crítica, alta, envejecida, aceptada y artículos cerrados TEN Validate cobertura y credenciales, confirman hallazgos, plazos, corrección, excepción, y recan ANTERIOR Inventory, scan setup, report, tickets, aprobaciones, rescane ANTE tención Registro y detección Silencio Todas las fuentes de registro, alertas, comentarios e incidentes requeridos Silencio Prueba fuente cobertura, tiempo, regla, generación de alertas, revisión, escalada y retención Silencio Fuente lista, configuración, alerta, ticket, revisión y cierre – Respaldo y recuperación Silencio Todos los trabajos de copia de seguridad y pruebas requeridas; éxito de la muestra, fracaso y servicios críticos Silencio Inspeccionar protección, respuesta a fallos, restauración, integridad, objetivos de recuperación, y lecciones TENIDO Empleos, alertas, restaurar la salida, ejercicio, corrección, retest Silencioso Supervisión del proveedor Silencio Todos los proveedores; muestra crítica, nueva, cambiada, involucrada en incidentes y relaciones de salida Titulación de pruebas, diligencia debida, contrato, vigilancia, derechos de incidencia, acción correctiva y salida del Inventario, evaluación, acuerdo, hallazgos, monitoreo, prueba de eliminación Silencio Respuesta del incidente Silencio Población total del evento y del incidente reconciliada para alertar, ayudar-desk, privacidad, legal y fuentes de operaciones Declaración de prueba, triage, analysis, evidence, notification, containment, eradication, recovery, and lessons – Timeline, tickets, log de pruebas, mensajes, recuperación y mejora Silencio Desarrollo

seguro Silencio Todos los repositorios, liberaciones, dependencias, excepciones, y hallazgos | Requisitos de examen, revisión, escaneo, secretos, dependencias, aprobación, implementación, corrección, y retestigos de los diarios de Pipeline, revisión, escaneo, ticket, liberación y validación

15.2 Conclusion language

Silencio **Ejemplo:** Para el período de servicio y examen definidos, el control fue diseñado y operado adecuadamente para 37 de 40 eventos de muestra. Tres absorciones tardías de acceso superaron la tolerancia aprobada. La administración asignó medidas correctivas, añadió una escalada automatizada y reprueba la eliminación oportuna confirmada para la población total posterior. La conclusión no abarca los sistemas excluidos del ámbito declarado. Silencio...

Herramientas de código abierto para CSF Work

Acoplamientos oficiales, inicios rápidos seguros, soporte CSF, evidencia y limitaciones.

Ciclo de vida de la ciberseguridad de la cadena de suministro



Autorización, validación, acción correctiva, y retesting convierten la producción técnica en evidencia útil.

Figure 7. From tool output to evidence

Silencio **Herramienta** Silencio ————— TEN CISO Assistant
 TENIDO GRC, Perfiles, riesgos, controles, evidencia TENIDO GV, ID, reportando TENIDO tención
 Wazuh TENIDO SIEM, control de puntos finales, integridad ANTE DE.CM, DE.AE, RS.MA
 Silencioso oscurecimiento Silencio Inventario de endpoints y pruebas de consulta TEN
 OpenSCAP TENIDO Evaluación de la configuración de Linux ANTE PR.PS, ID.IM ANTE –
 Greenbone Community Edition Silencioso Vulnerability assessment – ID.RA, ID.IM tención
 Trivy Silencio Código, imagen, dependencia, secreto y configuración de exploración TENIDO
 ID.RA, PR.PS ANTE Silencio OWASP ZAP – Evaluación autorizada de la aplicación web TENIDO
 Keycloak TENIDO Identidad, roles, autenticación y MFA TENIDO PR.AA ANTE – DefectDojo

tóxico Encontrar el seguimiento de la ingesta y la remediación Silencio Velociraptor Silencio
Visibilidad y respuesta a incidentes en Endpoint – Política Abierta Agente Silencioso Política
como código Silencioso GV.PO, PR.AA, PR.PS TEN OpenSearch TENIDO Buscar, análisis, tableros
de instrumentos y monitoreo de seguridad TENIDO DE.CM, DE.AE, GV.OV ANTE

16.1 Lista de verificación de validación de herramientas

- Aprobar propósito, propietario, alcance, datos, sistemas, alojamiento, acceso de apoyo y retención.
- Verificar la fuente oficial, versión, dependencias, integridad, método de actualización y configuración segura.
- Prueba una condición conocida que la herramienta debe detectar o bloquear.
- Prueba una condición permitida conocida para identificar fallos innecesarios.
- Compare la cobertura de herramientas con un activo independiente, agente, repositorio o población de identidad.
- Administración de restricciones, protección de credenciales e informes, cambios de registro y recuperación de herramientas de prueba.
- Definir la validación humana, escalada, excepción, corrección y retest.
- Revalidate después de actualizaciones de materiales, cambios de integración, cambios de configuración o fallos.

16.2 CISO Assistant

GRC, Perfiles, riesgos, controles, evidencia. Posible apoyo CSF: GV, ID, reportaje.

Documentación oficial: Abra la guía oficial de asistentes
CISO(<https://intuitem.gitbook.io/ciso-assistant>)

Quick start

Cree una organización ficticia, seleccione cinco resultados CSF, asigne propietarios, adjunte pruebas sanitarias, registre una brecha y construya un plan de acción.

Evidencia y limitación

Retener autorización, alcance, población objetivo, versión de herramientas y contenidos, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. La herramienta admite trabajo seleccionado; no puede certificar la alineación CSF, determinar el alcance completo o reemplazar el juicio humano calificado.

16.3 Wazuh

SIEM, control de puntos finales, integridad. Posible apoyo CSF: DE.CM, DE.AE, RS.MA.

Documentación oficial: Abra la guía oficial Wazuh realizada/u título](<https://documentation.wazuh.com/current/quickstart.html>)

Quick start

Conectar un punto final autorizado de laboratorio, crear un evento inofensivo, revisar la alerta, documentar la decisión y retener el evento y el ticket.

Evidencia y limitación

Retener autorización, alcance, población objetivo, versión de herramientas y contenidos, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. La herramienta admite trabajo seleccionado; no puede certificar la alineación CSF, determinar el alcance completo o reemplazar el juicio humano calificado.

16.4 osquery

Inventario de endpoint y pruebas de consulta. Posible apoyo CSF: ID.AM, PR.PS, PR.AA.

Documentación oficial: [Seguido]Abre la guía oficial del osquery realizada/u contacto](<https://osquery.readthedocs.io/en/stable/>)

Quick start

Query users, software, servicios, cifrado o procesos en un endpoint de laboratorio; registro de consultas, host, tiempo, salida y revisión.

Evidencia y limitación

Retener autorización, alcance, población objetivo, versión de herramientas y contenidos, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. La herramienta admite trabajo seleccionado; no puede certificar la alineación CSF, determinar el alcance completo o reemplazar el juicio humano calificado.

16.5 OpenSCAP

Evaluación de configuración de Linux. Posible soporte CSF: PR.PS, ID.IM.

Documentación oficial: [Seguido]Abre la guía oficial OpenSCAP efectuada/u contacto](<https://www.open-scap.org/getting-started/>)

Quick start

Evaluar un laboratorio Linux autorizado contra un perfil adecuado, corregir un ajuste aprobado, y comparar el antes y después de los informes.

Evidencia y limitación

Retener autorización, alcance, población objetivo, versión de herramientas y contenidos, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. La

herramienta admite trabajo seleccionado; no puede certificar la alineación CSF, determinar el alcance completo o reemplazar el juicio humano calificado.

16.6 Greenbone Community Edition

Evaluación de vulnerabilidades. Posible soporte CSF: ID.RA, ID.IM.

Documentación oficial: [Seguridad]Abre la guía oficial Greenbone Community Edition realizada/u contacto](<https://greenbone.github.io/docs/latest/>)

Quick start

Escanear sólo un objetivo de laboratorio aprobado, validar un hallazgo, corregirlo, cambiar y documentar el alcance y las limitaciones.

Evidencia y limitación

Retener autorización, alcance, población objetivo, versión de herramientas y contenidos, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. La herramienta admite trabajo seleccionado; no puede certificar la alineación CSF, determinar el alcance completo o reemplazar el juicio humano calificado.

16.7 Trivy

Código, imagen, dependencia, secreto y análisis de configuración. Posible soporte CSF: ID.RA, PR.PS.

Documentación oficial: Abra la guía oficial Trivy realizada/u título](<https://trivy.dev/latest/>)

Quick start

Escríbete una imagen de laboratorio o un repositorio de pruebas, protege el informe, valida un resultado, corrígelo y vuelve a escanear.

Evidencia y limitación

Retener autorización, alcance, población objetivo, versión de herramientas y contenidos, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. La herramienta admite trabajo seleccionado; no puede certificar la alineación CSF, determinar el alcance completo o reemplazar el juicio humano calificado.

16.8 OWASP ZAP

Evaluación autorizada de la aplicación web. Posible soporte CSF: ID.RA, ID.IM.

Documentación oficial: Abra la guía oficial OWASP ZAP efectuada / u fiel](<https://www.zaproxy.org/getting-started/>)

Quick start

Proxy una aplicación de entrenamiento local, empezar con análisis pasivos, validar un hallazgo, y conservar el alcance y los resultados aprobados.

Evidencia y limitación

Retener autorización, alcance, población objetivo, versión de herramientas y contenidos, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. La herramienta admite trabajo seleccionado; no puede certificar la alineación CSF, determinar el alcance completo o reemplazar el juicio humano calificado.

16.9 Keycloak

Identidad, roles, autenticación y MFA. Posible apoyo CSF: PR.AA.

Documentación oficial: [obedeció]Abre la guía oficial de Keycloak realizada/u contacto] (<https://www.keycloak.org/guides>)

Quick start

Crear un reino de laboratorio, usuarios, roles y MFA; probar menos privilegios, acceso fallido y eliminación; exportar evidencia de configuración sanitaria.

Evidencia y limitación

Retener autorización, alcance, población objetivo, versión de herramientas y contenidos, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. La herramienta admite trabajo seleccionado; no puede certificar la alineación CSF, determinar el alcance completo o reemplazar el juicio humano calificado.

16.10 DefectoDojo

Encontrar captación y seguimiento de remediación. Posible apoyo CSF: ID.RA, ID.IM, GV.OV.

Documentación oficial: [Seguido]Abre el defecto oficialDojo guía seleccionada/u contacto] (<https://docs.defectdojo.com/>)

Quick start

Importar un informe de laboratorio, validar y asignar un hallazgo, registrar corrección, retestarlo y cerrarlo con prueba.

Evidencia y limitación

Retener autorización, alcance, población objetivo, versión de herramientas y contenidos, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. La herramienta admite trabajo seleccionado; no puede certificar la alineación CSF, determinar el alcance completo o reemplazar el juicio humano calificado.

Velociraptor

Visibilidad del punto final y respuesta a incidentes. Posible soporte CSF: DE.CM, RS.AN.

Documentación oficial: [Seguridad]Abre la guía oficial Velociraptor realizada/u contacto] (<https://docs.velociraptor.app/>)

Quick start

Utilice un cliente de laboratorio aislado, recoger un artefacto aprobado inofensivo, y propósito de registro, alcance, colección, revisión y preservación.

Evidencia y limitación

Retener autorización, alcance, población objetivo, versión de herramientas y contenidos, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. La herramienta admite trabajo seleccionado; no puede certificar la alineación CSF, determinar el alcance completo o reemplazar el juicio humano calificado.

16.12 Open Policy Agent

Política como código. Posible apoyo CSF: GV.PO, PR.AA, PR.PS.

Documentación oficial: [Seguridad]Abre la guía oficial de Agentes de Políticas Abiertas efectuada/u contacto](<https://www.openpolicyagent.org/docs>)

Quick start

Escribir una regla de laboratorio que requiera un propietario, clasificación y entorno aprobado; probar los insumos permitidos y negados.

Evidencia y limitación

Retener autorización, alcance, población objetivo, versión de herramientas y contenidos, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. La herramienta admite trabajo seleccionado; no puede certificar la alineación CSF, determinar el alcance completo o reemplazar el juicio humano calificado.

16.13 OpenSearch

Búsqueda, análisis, paneles y monitoreo de seguridad. Posible apoyo CSF: DE.CM, DE.AE, GV.OV.

Documentación oficial: [Seguridad]Abre la guía oficial OpenSearch efectuada/u contacto] (<https://opensearch.org/docs/latest/getting-started/>)

Quick start

Cargar eventos de seguridad sintéticos, construir una búsqueda y panel de control, documentar la cobertura de datos, acceso, retención, revisión y limitaciones.

Evidencia y limitación

Retener autorización, alcance, población objetivo, versión de herramientas y contenidos, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. La herramienta admite trabajo seleccionado; no puede certificar la alineación CSF, determinar el alcance completo o reemplazar el juicio humano calificado.

16.14 Official NIST tools

CSF 2.0 Herramienta de referencia: [fieltro]Explore y exporte el CSF certificado Core/u título](<https://csrc.nist.gov/Projects/cybersecurity-framework/Filters#/csf/filters>)

**** Perfiles organizacionales:**** [] Guía de perfil y plantillas seleccionadas/u fiell](<https://www.nist.gov/cyberframework/profiles>)

17. Libro de juegos CSF del administrador

Las preguntas, las rutinas de gobernanza, los tableros de control y los administradores de decisiones deben controlar.

17.1 Preguntas mensuales

- ¿Qué cambió en misión, sistemas, datos, amenazas, obligaciones, proveedores o apetito de riesgo?
- ¿Qué riesgos exceden la tolerancia y quién tiene autoridad para decidir?
- ¿Son las conclusiones del perfil actual apoyadas por pruebas fiables?
- ¿Qué planes de acción son tardíos, bloqueados, insuficientes o dependientes de otros?
- ¿Los proveedores críticos son supervisados e incluidos en el trabajo de recuperación y incidentes?
- ¿Las fallas de control, incidentes, ejercicios, pruebas y faltas cercanas han mejorado?
- ¿Pueden recuperarse los servicios críticos dentro de los objetivos aprobados?
- ¿Qué limitaciones debe entender el liderazgo antes de confiar en el tablero?

17.2 Dashboard

Area Silencio ** Cuestión de gestión** ...----- -

Gobernanza permanente ¿La estrategia, la política, las funciones, los recursos y la supervisión están alineados al riesgo? Verde / Amarillo / Rojo TEN TERRITOR TEN ANTE ¿Es el alcance actual y está aprobado el perfil de destino? Verde / Amarillo / Rojo Silencio ¿Qué riesgos residuales exceden la tolerancia? Verde / Amarillo / Rojo - Activos Silencio ¿Son conocidos activos críticos, datos, flujos y proveedores? Verde / Amarillo / Rojo tención permanente ¿Operan las salvaguardias de identidad, datos, plataforma, capacitación y resiliencia? Verde / Amarillo / Rojo Silencioso Detección ¿El monitoreo está completo, revisado y conectado a

criterios de incidentes? Verde / Amarillo / Rojo Silencio Respuesta Silencio ¿Los incidentes son triaged, analizados, comunicados, contenidos y erradicados? Verde / Amarillo / Rojo ¿Se han demostrado la integridad de la restauración y los objetivos de servicio crítico? Verde / Amarillo / Rojo Ø Mejoramiento Silencio ¿Se han corregido los resultados y se han vuelto a comprobar de forma independiente? Verde / Amarillo / Rojo

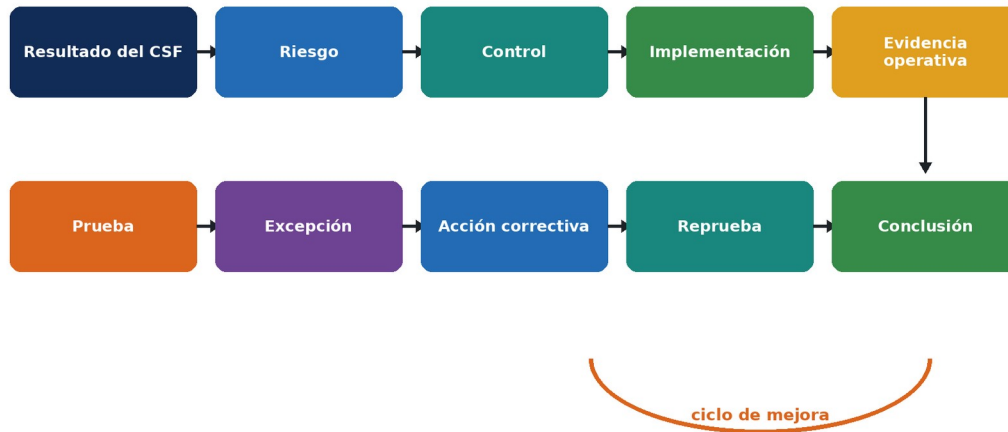
17.3 Errores comunes

- Tratar a CSF como una lista de verificación de TI en lugar de trabajo de riesgo empresarial.
- Comenzar con herramientas en lugar de misión, alcance, riesgo y resultados.
- Marcar los resultados obtenidos únicamente del texto de política.
- Usando una sola partitura que esconde debilidades críticas y diferencias de alcance.
- Llamar niveles de madurez sin entender el contexto previsto de NIST.
- Copiar un perfil de destino sin adaptarlo al riesgo organizativo.
- Ignorar proveedores, servicios en la nube, OT, datos, personas, instalaciones y dependencias.
- Cierra los resultados sin volver a probar.
- Describir la alineación CSF como cumplimiento legal o certificación NIST.

18. From Beginner to Junior Analyst

Un camino seguro y honesto hacia GRC, riesgo, cumplimiento y análisis de ciberseguridad.

Cadena del resultado a la evidencia



Aprender, mapa, test, reportar y aplicar con evidencia de cartera honesta.

Figura 8. Vía de analista junior

18.1 Funciones de nivel de entrada

Junior GRC Analista

Análisis del riesgo de ciberseguridad

Compliance Analyst

Analista de Controles de Seguridad

Third-Party Risk Analyst

Análisis de la seguridad

Cybersecurity Program Analyst

Junior Security Analyst

Analista de Auditoría

18.2 Trabajar un analista junior puede actuar

- Mantener inventarios de activos, datos, sistema, riesgo, obligación, proveedor y evidencia.
- Reunir y organizar pruebas para los resultados de CSF.
- Revisar el acceso, la vulnerabilidad, la capacitación, la tala, la copia de seguridad, el proveedor y las muestras de incidentes.

- Document Profile status, gaps, limitations, owners, and action plans.
- Seguimiento de acciones correctivas, excepciones, aceptaciones de riesgo y pruebas.
- Preparar paneles y materiales de reunión sin ocultar incertidumbre.
- Ejercicios de apoyo, plazos de incidentes, lecciones aprendidas y actualizaciones del plan.
- Proteger información confidencial y seguir límites de autorización.

18.3 Portafolio proof

Silencio **Skill** Silencio** Silencio... TENCIÓN FORMULADA CON EL TERRITORIO DE SUPERVISIÓN – Cartografía básica Silencio Aplicabilidad y matriz de pruebas – Gestión de activos Silencioso Sistema, datos, proveedor e inventario de flujo – Riesgo Silencioso registro de riesgo con apetito, tolerancia, respuesta y decisión residual tención Perfiles – Perfiles actuales y de objetivos con brechas priorizadas – Testing – Acceso, vulnerabilidad, copia de seguridad, registro y hojas de prueba de proveedores Respuesta del incidente Silencio Sintético timeline, evidence log, communication, and lessons Silencio Manejo de comunicación Silencio Una página dashboard y declaración de riesgo ejecutivo

19. Laboratorio Ficcional y Portfolio

Un entorno de práctica completo utilizando información sintética y sistemas de laboratorio autorizados.

Harbor Light Services es una organización ficticia que proporciona un portal de clientes, centro de llamadas, colaboración en la nube, integración de pagos, fuerza de trabajo remota y análisis anfitriones por proveedores. Cada persona, cuenta, dirección, activo, evento, registro de clientes y proveedor es inventado.

Project 1 — Scope and context

Definir misión, partes interesadas, obligaciones, servicios críticos, dependencias, exclusiones y propietarios.

Project 2 — Asset and data map

Construir inventarios y un diagrama de flujo de datos autorizado.

Proyecto 3 - Riesgo

Cree una amenaza, vulnerabilidad, probabilidad, impacto, tratamiento y registro de riesgo residual.

Project 4 — Profiles

Cree perfiles de objetivos actuales y basados en riesgos.

Project 5 — Controles y pruebas

Diseñar y ejecutar pruebas ficticias para el acceso, vulnerabilidades, registros, respaldos y proveedores.

Project 6 — Incident

Analizar eventos sintéticos, declarar un incidente, preservar evidencia, contener, erradicar, restaurar y aprender.

Project 7 — Tools

Utilice tres herramientas Capítulo 16 en un laboratorio aislado y autorización de registro, versión, alcance, hallazgos, corrección y retest.

Proyecto 8 - Informe ejecutivo

Prepare un dashboard, declaraciones de alto riesgo, plan de acción, decisiones y limitaciones.

Portfolio ethics:* Label todos trabajan como entrenamiento ficticio. Nunca publique información de empleador, cliente, paciente, cliente, empleado, proveedor, arquitectura, vulnerabilidad, credenciales o incidentes sin autorización explícita. Silencio Silencio.

20. Plan de aprendizaje de 30 días

Un mes realista de lectura, práctica, trabajo de cartera y preparación de entrevistas.

Silencio **Week** Silencio** Silencio ————— tención Semana 1 Silencio
CSF propósito, Core, six Funciones, contexto, y activos peru Scope memo, mapa de los interesados, inventario de activos y datos TEN Week 2 TENIDO Riesgo, Perfiles, Tiers, Gobernanza y cadena de suministro TENIDO Registro de riesgos, Perfiles actuales y de objetivos, Tiering de proveedores tención semana 3 — Salvaguardias, monitoreo, respuesta, recuperación, evidencia y pruebas TENENCIA Cinco pruebas de control, archivo de incidentes, evidencia de recuperación Silencio Semana 4 Silencio Herramientas, reportajes, portafolio y entrevistas — Portafolio Sanitizado, dashboard, respuestas practicadas

20.1 hábitos diarios

Lea una sección oficial NIST o grupo de resultados.

Explíquelo en lenguaje claro sin cambiar su significado.

Crear un elemento de evidencia ficticia.

Prueba su integridad, alcance, fecha, propiedad y fiabilidad.

Escribe una conclusión, acción correctiva o lección.

21. Preparación de entrevistas

Respuestas rápidas y precisas para analistas y administradores junior.

¿Qué es NIST CSF 2.0?

Un marco flexible centrado en los resultados que ayuda a las organizaciones a comprender, evaluar, priorizar y comunicar el riesgo de ciberseguridad utilizando el núcleo, los perfiles, los niveles y los recursos de apoyo.

¿Cuáles son las seis Funciones?

Govern, Identificar, Proteger, Detectar, Responder y Recover.

¿Por qué fue agregado Govern?

Hace explícita la rendición de cuentas, la política, la estrategia de riesgo, la integración de los riesgos institucionales, la supervisión y el riesgo de cadena de suministro.

¿Qué es un perfil actual?

A description of Core outcomes a defined scope is currently achieving or attempting to achieve, including how or to what extent.

¿Qué es un perfil objetivo?

Los resultados básicos prioritarios que la organización selecciona para un estado futuro definido basado en la misión, el riesgo, las obligaciones, los interesados y los recursos.

¿Qué son los Tiers?

Context for the rigor of cybersecurity risk governance and management practices: Partial, Risk Informed, Repeatable, and Adaptive.

¿CSF certifica el cumplimiento?

No. La alineación CSF no crea el cumplimiento legal ni la certificación NIST. Las obligaciones aplicables y los controles aplicados deben evaluarse por separado.

¿Cómo verificas un resultado?

Definir el alcance y los criterios, evaluar el diseño de control, obtener una población completa, muestra por riesgo, inspeccionar y repercutir, registrar excepciones, corregir, retest y declarar una conclusión apoyada.

¿Cómo deben usarse las herramientas?

Sólo con autorización y como una fuente de evidencia. Validar la cobertura y los resultados, proteger los productos, corregir las brechas confirmadas y volver a probar.

¿Cómo priorizas las brechas?

Utilizar los efectos de la misión, la amenaza, la probabilidad, la crítica de activos y proveedores, las obligaciones, la exposición, las dependencias, los controles existentes, el costo, la viabilidad y el apetito de riesgo.

Silencio **Respuesta de Manager de 60 segundos:** Uso CSF 2.0 para conectar la ciberseguridad con el riesgo de negocio. Definimos el alcance y las partes interesadas, seleccionamos los resultados aplicables, construimos perfiles de objetivos actuales y basados en riesgos, priorizamos las lagunas en el apetito y las obligaciones, los planes de acción de los fondos, las pruebas de funcionamiento, incluyen a los proveedores y informamos claramente sobre las decisiones y limitaciones. Las herramientas apoyan el trabajo, pero las personas siguen siendo responsables de su alcance, juicio, corrección y riesgo residual. Respuesta

22. Plantillas y listas de verificación

- Estructuras útiles para un sistema de organización aprobado*.

22.1 Profile record

- Alcance, propósito, propietario, patrocinador, partes interesadas, fecha y gatillo de revisión
- Función, categoría y identificador de subcategoría
- Aplicabilidad y racionalidad
- Situación actual, aplicación, propietario, evidencia, prueba, excepción y limitación
- Situación y prioridad de los objetivos
- Gap, risk, action, interim protection, owner, resources, date, dependency and retest
- Contexto actual y de destino donde útil
- Historial de aprobación y versión

22.2 Risk register

- Objetivo, activo, servicio, datos, proveedor y propietario
- Amenaza, vulnerabilidad, escenario y resultados CSF afectados
- Controles y pruebas existentes
- probabilidad, impacto, riesgo inherente y método
- Respuesta, acción, propietario, recursos, fecha y dependencia
- Riesgo residual, comparación de apetito/tolerancia y autoridad de aceptación
- Indicador, gatillo de revisión, expiración de excepción y retest

22.3 Ficha de control

- Resultado, riesgo, control, propietario, frecuencia, sistemas, ubicaciones y periodo
- Criterios de diseño y pruebas esperadas
- Comprobación completa de población
- Método de muestra y elementos seleccionados
- Procedimiento, evidencia inspeccionada, reperformance y resultado
- Excepciones, causa, impacto, acción, propietario, fecha y protección provisional
- Retest, conclusión, limitaciones, revisor y aprobación

22.4 Revisión del proveedor

- Servicio, propietario, crítica, acceso, datos, ubicaciones, subcontratistas, dependencias y alternativas
- debida diligencia, autenticidad, desarrollo seguro, vulnerabilidades, resiliencia, historial de incidentes y preocupaciones financieras o operacionales
- Requisitos contractuales, derechos de prueba, notificación, recuperación, retorno/destrucción y salida
- Vigilancia, hallazgos, excepciones, acciones correctivas, ejercicios, incidentes, cambios, renovación y terminación

22.5 Lista de comprobación de la preparación del administrador

- Patrocinador, funciones, recursos, políticas y estrategia de riesgo aprobada
- Alcance, partes interesadas, obligaciones, servicios críticos, dependencias y proveedores actuales
- Activo, datos, sistema, servicio, identidad, vulnerabilidad y poblaciones de riesgo reconciliadas
- Perfiles actuales y de objetivos apoyados y aprobados
- Plan de acción basado en el riesgo financiado y seguido
- Pruebas de seguridad, vigilancia, incidentes y recuperación
- Controles de ciclo de vida del proveedor
- Métricas relacionadas con el riesgo y los resultados
- Excepciones, aceptaciones, limitaciones y pruebas visibles para los encargados de adoptar decisiones

23. Índice de Glosario y Asunto

Definiciones en inglés y una guía para temas importantes.

Categorías. Un grupo de resultados relacionados con la ciberseguridad dentro de una función.

**** Perfil comunitario.**** A published baseline of CSF outcomes for shared sector, technology, threat, or use-case needs.

Tranquila. La jerarquía de Funciones, Categorías y Subcategorías que describe los resultados de la ciberseguridad.

Perfil actual. Los resultados de un alcance definido están alcanzando o tratando de alcanzar, incluyendo cómo o hasta qué punto.

**** Riesgo de seguridad.**** The possible effect of uncertainty on information and technology and the related organizational objectives.

Función El nivel de resultados CSF más alto: Govern, Identificar, Proteger, Detectar, Responder o Recuperar.

**** Ejemplo de implementación.**** Una ilustración nocional y orientada a la acción de una posible manera de apoyar un resultado básico.

Referencia informativa Una asignación entre un resultado básico y otra norma, directriz, regulación o fuente.

**** Perfil organizacional.**** Un mecanismo para describir la postura de ciberseguridad actual y/o dirigida utilizando los resultados básicos.

**** Riesgo residual.**** El riesgo que queda después de que se examinen los controles y las respuestas.

#Aguanta el apetito # La amplia cantidad y tipo de riesgo que una organización está dispuesta a perseguir o retener.

Tolerancia de la tinta** Variación aceptable en torno a objetivos específicos o desempeño.

Subcategoría. Un resultado específico de ciberseguridad dentro de una categoría.

Perfil de Sargento. Los resultados seleccionados y priorizados tienen por objeto alcanzar un alcance definido.

Más. Context for the rigor of cybersecurity risk governance and risk-management practices.

23.1 Subject index

Tema Silencioso** Silencio————— Silencioso control de acceso Silencio 6, 15–16, 22 Silenciosos Silenciosos 14, 17 Silencio Silencio Inventario de Activos Silencioso 5, 15, 22 Silencio Herramientas de código abierto tención de la auditoría TENIDO 14–15, 22 TENIDO Perfiles de organización TENIDO 2–3, 10 TENIDO Silencio Silencio Silencio Silencio , 18 Silencio Silencio TENIDO ANTERIOR ANTERIOR 2, 4-9 ANTE ANTERIOR

ANTERIOR ANTERIOR ANTERIOR ANTERIOR ANTERIOR ANTERIOR ANTERIOR
ANTERIOR ANTERIOR ANTERIOR ANTE ANTERIOR ANTERIOR ANTERIOR ANTERIOR
ANTERIOR ANTE 2, 4 ANTE 9 Silencioso Detección Silencioso 7 Silencioso apetito Silencio 4, 12
TENIDO Evidencia TENIDO 14–16 TENIDO Evaluación del riesgo TENIDO 5, 12, 22 Silencio
Govern Silencio 4, 12–13, 17 Silencioso cadena de suministro Silencio Identificar Apocalipsis 5
Silencioso Tiers Silencioso 2, 11 Silencio Respuesta del incidente Silencio 8, 15, 19 Silencio
Silencioso analista junior Silencio 18–21 Silencio Gestión de la Vulnerabilidad

24. Referencias oficiales y estudio ulterior

Características actuales NIST publicaciones, herramientas y documentación de proyectos utilizados para la verificación.

[Seguido] (<https://doi.org/10.6028/NIST.CSWP.29>)

[](<https://www.nist.gov/cyberframework>)

[](<https://csrc.nist.gov/Projects/cybersecurity-framework/Filters#/csf/filters>)

[](<https://www.nist.gov/cyberframework/faqs>)

Seguido

[](<https://www.nist.gov/cyberframework/informative-references>)

[indicau]CSF 2.0 Guía de Recursos y Resúmenes — SP 1299 made/u
fiel](<https://doi.org/10.6028/NIST.SP.1299>)

[Seguido] [Informes de organización](#) [Guía de inicio rápido](#) — SP 1301

Guía de inicio rápido de los niveles: SP 1302 obtenidos/u
fiel](<https://doi.org/10.6028/NIST.SP.1302>)

[Seguido]u Guía de inicio rápido de la gestión del riesgo institucional — SP 1303
operacionales/u contactos](<https://doi.org/10.6028/NIST.SP.1303>)

[Seguido] Guía de inicio rápido de pequeñas empresas — SP 1300 made/u fiel]
(<https://doi.org/10.6028/NIST.SP.1300>)

[](<https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final> SP 800-53 Rev. 5

[se]u fielNIST SP 800-61 Rev. 3 — Respuesta del incidente realizada/u
contacto](<https://csrc.nist.gov/pubs/sp/800/61/r3/final>)

[indicau]NIST SP 800-218 — Secure Software Development Framework made/u
fiel](<https://csrc.nist.gov/pubs/sp/800/218/final>)

Seguido

Silencio **Recordaje final:** El núcleo CSF es estable, mientras que los ejemplos de implementación en línea, Referencias informativas, orientación, cartografías, amenazas,

tecnologías y obligaciones pueden cambiar. Verify current official NIST sources and organization-specific requirements before acting. Silencio.